

Cybersecurity Incident Analysis Report: Suspicious Email

Date: March 25, 2026

Subject: Analysis of Phishing Email - "[Action Required] Remote Work Policy Update"

Classification: High Risk / Malicious

Analyst: Tova Kleinkaufman

Strong Indicators of Compromise (High Confidence)

These indicators provide direct evidence of malicious intent and can independently justify classification.

1.1 Mismatch between sender and domain:

Indicator: Domain mismatch (spoofing / typosquatting)

Evidence: Return-Path: updates@corp-hra.co Received: **From** "HR Support"
hr-portal.corp-hr.co

Analysis: There is a mismatch between the attackers domain corp-hra.co and legit HR domain corp-hr.co this is a classic typosquatting technique where attackers register lookalike domains to impersonate legitimate organizations. Such small variations are difficult for users to detect and are commonly used in phishing campaigns.

Risk: High risk of phishing leading to credential theft or malware infection.

1.2 Malicious Links

Indicator: URL Mismatch (Link Masking / Shadow Redirect).

Evidence: Visible Link (UI): <https://go.corp-login.co/r?id=78231> actual Destination (HTML href): <https://asemailmgmtus.com/r?id=78231>

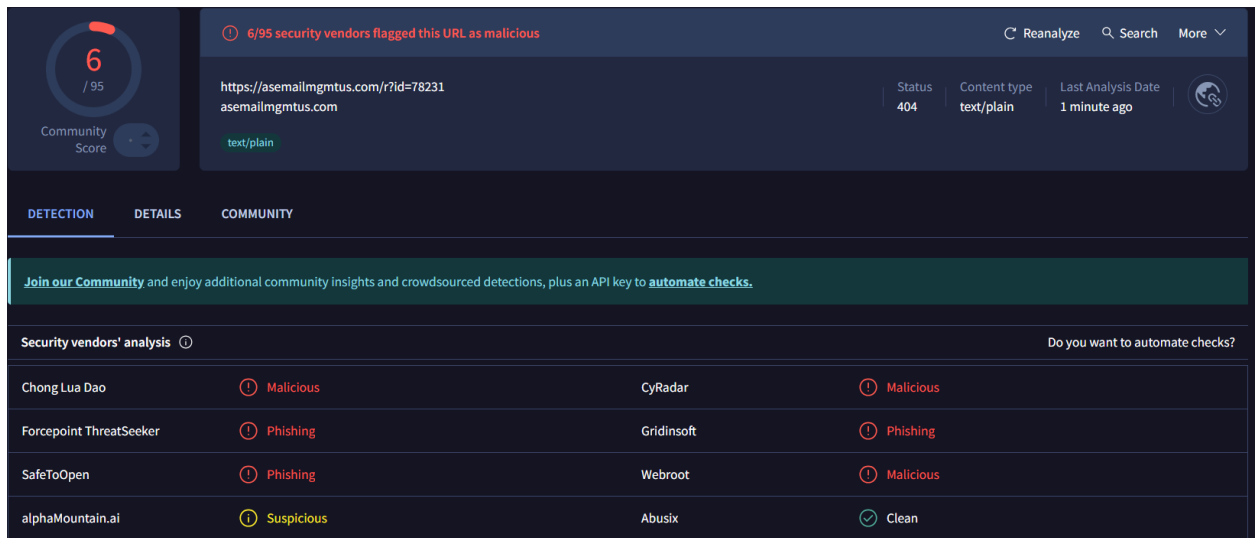
Analysis: The destination domain asemailmgmtus.com does not belong to the organization and is likely a newly registered domain used exclusively for this campaign to host a credential harvesting page or deliver malware this is another indicator of a phishing attack as the attacker is using **Link Masking** to display a seemingly legitimate "corporate-looking" URL (corp-login.co) in the email body, while the actual href attribute points to a completely different and untrusted domain (asemailmgmtus.com) and by submitting the link in VT it is flagged as malicious and related to phishing threats.

Risk: High risk of credential theft.

VT Link:

<https://www.virustotal.com/gui/url/d55c358c83532b4e90ad1f05dea63d25ffaecdbfc33e1b>

[aeaf541d7a8e909cf7?nocache=1](https://www.virustotal.com/aeaf541d7a8e909cf7?nocache=1)



1.3 Suspicious Attachments - Double Extension Attack

Indicator: Double Extension Attack

Evidence: attachments: Policy_Update.pdf.zip

Analysis: This is a compressed archive (ZIP) not a PDF. Attackers name it like a document (.pdf) to make it look harmless. This is a classic Double Extension trick. The attacker names the file with .pdf in the middle to make it appear as a harmless document to the user. In reality, the file is a ZIP archive that acts as an executable delivering malware to the users' host attackers use this method for two main reasons: to bypass security filters and to deceive users.

Risk: High risk of malware delivery via deceptive attachment.

1.4 Suspicious Attachments - Right-to-Left Override (RLO) Attack (U+202E)

Indicator: Unicode Manipulation (RLO - U+202E).

Evidence: Policy_Update.pdfu202Eexe. **Visual Representation (User View):**

Policy_Update.exe.pdf **Actual File Type (System View):** .exe (Executable)

Analysis: The attacker is using the Right-to-Left Override (RLO) unicode character to flip the visual order of the characters in the filename. By inserting U+202E before "exe", the system renders the filename backwards to the user making it appear as a harmless .pdf file but in reality, the file remains a dangerous executable (.exe).

Risk: High risk of hidden executable malware

1.5 Content Inconsistency

Indicator: Generic Targeting / Dynamic Content Mismatch

Evidence: Visible Body: "Dear John.." HTML Source Code: "Dear Employee"

Analysis: A major red flag in phishing is the inconsistency between the rendered text and the underlying HTML code legitimate corporate communications use automated systems that ensure name consistency across all email formats (HTML and Plain Text). In addition this discrepancy is a strong indicator of a mass phishing campaign.

Risk: Medium - High risk of mass-targeted phishing and impersonation.

Supporting Indicators (Require Correlation) Medium

2.1 Hidden Form Implementation

Indicator: Hidden Form / Silent Tracking (Tracking Pixel Technique)

Evidence: `<form action="https://cdn.corp-login.co/track" method="post" style="display:none;visibility:hidden;">
<input type="hidden" name="uid" value="78231">
</form>`

Explanation: The sender embedded a hidden form that is invisible to the recipient's UI but is designed to execute a POST request or a tracking action once the email is rendered by certain clients. By using a unique ID (**uid="78231"**) the sender can confirm that the email was opened, used to track email opens and user interaction. Common in both marketing and phishing campaigns.

Risk: Medium.

2.2 Suspicious Mail Routing (hop):

Indicator: Untrusted/anomalous sending infrastructure.

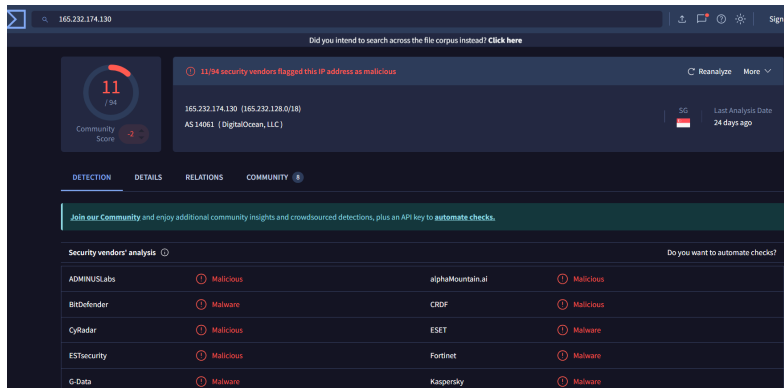
Evidence: Reading the Received lines (the way the email passes -servers) we see
Received: **from relay.corp-hra.co (noc.hra-securemail.net [165.232.174.130])**
Received: **from hr-portal.corp-hr.co (cloud-hosting-103-56-114-117.provider.net [103.56.114.117])**

Analysis: The email hops through multiple anomalous sending domains hosted on public cloud hosting infrastructures.

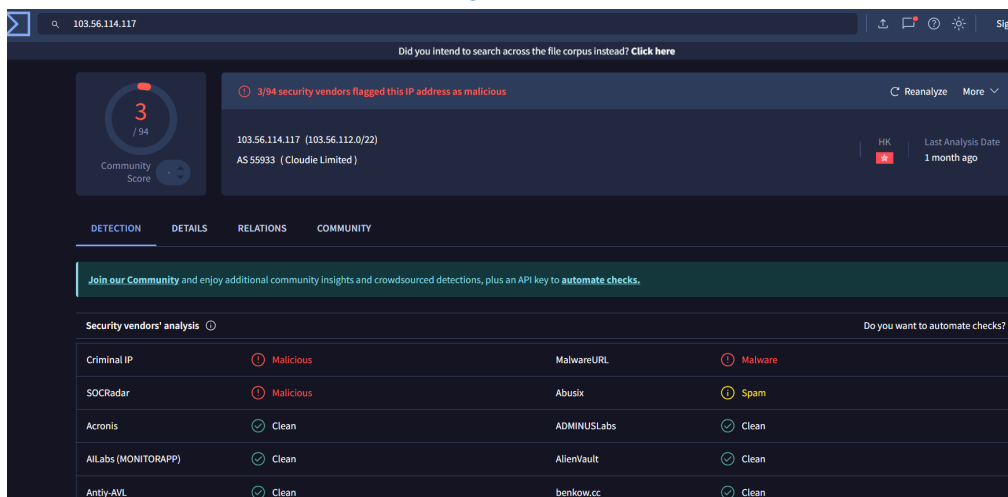
Use of public cloud infrastructure is **not inherently malicious**, but may be inconsistent with expected corporate mail flow.

Risk: Medium (supporting evidence only).

VT Link: <https://www.virustotal.com/gui>



VT Link: <https://www.virustotal.com/gui/ip-address/103.56.114.117/detection>



2.3 Authentication Failures:

Indicator: Email authentication failure

Evidence: Authentication-Results: **mx.training-lab.local**;

spf=pass smtp.mailfrom=updates@corp-hra.co;

dkim=fail (bad signature) header.d=corp-hr.co;

dmarc=fail (p=reject dis=none) header.from=corp-hr.co

Analysis: Every email has to go through a process before receiving the email **SMTP ->**

MX Record-> Hop-> SPF-> DKIM-> DMARC ->Inbox/Spam/Block.

Analysis: In the email we see the following:

- **spf=pass** -(Is the sending server authorized to send on the domain name?) yes
- **dkim=fail** -(did the email be changed on the way) -fail ,
- **dmarc=fail** -(what to do if something went wrong) -fail , This is an indication of However, these failures **can also occur due to forwarding or configuration issues**, and therefore require correlation with stronger indicators.

Risk:Medium (supporting evidence only).

2.4 Sender Origin IP Header:

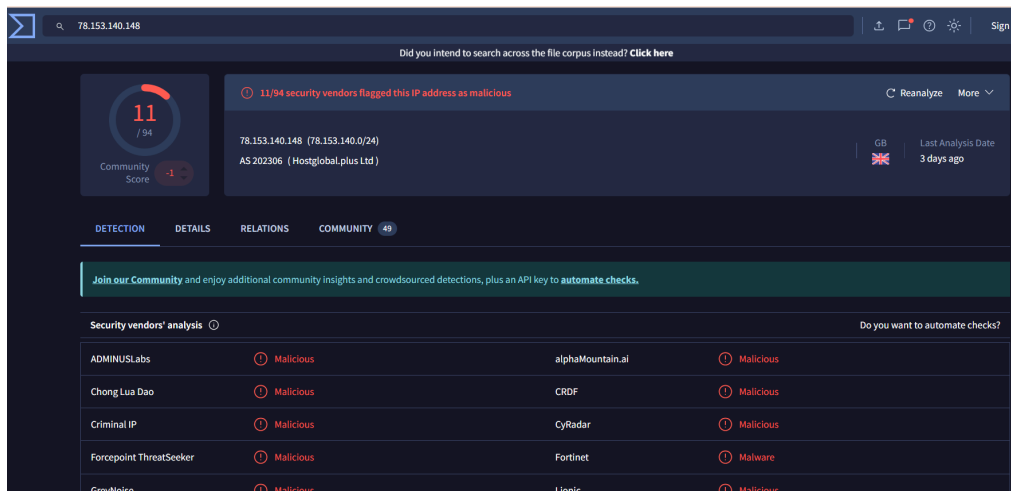
Indicator: Residential/Non-Corporate Source IP.

Evidence: X-Originating-IP: [78.153.140.148]

Analysis: The originating IP is different from the mail relay servers which are hosted in cloud hosting services and the IP appears to be a residential or non-corporate IP. While unusual, this alone does not confirm malicious activity.

Risk: Medium.

VT Link: <https://www.virustotal.com/gui/ip-address/78.153.140.148/detection>



Less Supporting Indicators (Require Correlation) Low

3.1 Use of Bcc Field:

Indicator: Bulk phishing distribution.

Evidence: We see the sender used BCC when sending the email. Bcc: johnsnow@corp-hr.co (visible in headers).

Analysis: The Bcc field is commonly used in mass phishing campaigns to send emails to many recipients without revealing their identities to each other; it is common in phishing, but also used in legitimate bulk emails.

Risk: Low–Medium.

3.2 Use of "undisclosed recipients":

Indicator: Concealed recipient list (Bulk Mailing)

Evidence: for <undisclosed-recipients> This is often a red flag because attackers use this to mask the fact that the email was sent to thousands of targets simultaneously, rather than being a personal corporate email.

Analysis: While this is common in phishing campaigns, it is also widely used in legitimate bulk communications (e.g., newsletters, organizational updates) to preserve

recipient privacy. In this context, it may support the hypothesis of a mass phishing campaign, but **does not independently indicate malicious activity**

Risk: Low–Medium

3.3 Base64 encoding

Indicator: Payload Obfuscation

Evidence: Content-Transfer-Encoding: **base64**

Analysis: Legitimate emails rarely include hand-encoded attachments, while attackers use this method to obfuscate file contents and deliver malware. This is a standard method for encoding attachments in email. Becomes relevant only when combined with suspicious file types.

Risk: Low–Medium (contextual).

3.5 Trying to appear “secure”:

Indicator: Attempt to establish "False Credibility.

Evidence: **relay.corp-hra.co (noc.hra-securemail.net [165.232.174.130])**

Analysis: Use of trust-related keywords may attempt to increase credibility, but this is not a reliable indicator on its own.

Risk: Low.

3.6 Social Engineering Techniques

Indicator: Psychological Manipulation (sense of urgency).

Evidence: Subject: **[Action Required] Remote Work Policy Update.**

Explanation: The subject line uses urgency (“Action Required”), a common social engineering technique designed to prompt immediate user action. While such language is frequently used in phishing campaigns, it is also common in legitimate organizational communications (e.g., HR or IT notifications)

Risk Assessment: Low.

3.7 Email MIME Boundary

Indicator: Non-Standard/Generic MIME Boundaries.

Evidence: Content-Type: multipart/mixed; boundary="BOUNDARY_MIXED_0001"
Content-Type: multipart/alternative; boundary="BOUNDARY_ALT_0002"

Analysis: MIME boundaries are strings of 7-bit US-ASCII text that define the boundaries between message parts in a MIME message.

The numbers 0002/0001 are overly simplistic and sequential.

Legitimate email systems typically generate long, complex, and unique boundary strings. Simple structure may suggest scripting, but MIME formatting varies widely across systems.

Risk: Low.

4. Attack Flow Analysis

The email follows a common phishing attack chain:

- * User receives spoofed HR-themed email
- * Urgency (“Action Required”) encourages immediate action
- * Two possible attack paths:

Link click → phishing site / credential harvesting

Attachment open → malware execution

5. Risk Assessment

If Link is Clicked:

- * Credential harvesting.
- * Redirection to malicious infrastructure.

If Attachment is Opened:

- * Execution of malicious payload.
- * Potential endpoint compromise.

Organizational Impact:

- *Account compromise.
- *Initial access vector.
- *Potential lateral movement / data exposure.

Final Assessment

Based on the presence of **multiple high-confidence indicators**, including:

- * Domain impersonation.
- * Link mismatch
- * Deceptive executable attachments

Combined with supporting signals:

- * Authentication anomalies.
- * Bulk distribution patterns
- * Tracking mechanisms

This email is classified as a high-risk phishing attempt with malware delivery capabilities.

Conclusion:

This email demonstrates a **coordinated phishing campaign** combining:

Social engineering.

Credential harvesting techniques.

Malware delivery mechanisms.

While some indicators are contextual, the presence of **multiple strong indicators** provides high confidence in malicious intent.

Recommendation:

Do not interact with the email. Report to the security team and block associated domains and IPs.